TRƯỜNG ĐẠI HỌC VĂN LANG
KHOA CÔNG NGHỆ THÔNG TIN

BÁO CÁO ĐỀ TÀI

AN NINH NHÂN SỰ, ĐỊNH DANH VÀ CHỨNG THỰC

Đề Tài:

TẤN CÔNG VÀ PHÒNG CHỐNG KERBEROS TICKET FORGING

SVTH: Lâm Xuân Phú_2274802010666
Phạm Nguyễn Thanh Vy_2274802011036
Trần Thành Vũ_
GVHD: ThS. Bùi Duy Cương

TP. Hồ Chí Minh – năm 2025

CỘNG HÒA XÃ HỘI CHỦ NGHĨA VIỆT NAM

Độc lập – Tự do – Hạnh phúc

PHIẾU NHẬN XÉT SINH VIÊN

CỦA GIẢNG VIÊN HƯỚNG DẪN

1.Họ và tên sinh viên: Lâm Xuân Phú_2274802010666

Phạm Nguyễn Thanh Vy_2274802011036

Trần Thành Vũ_

Lớp: 242_71NWCS40603_01

Ngành: Mạng máy tính và Truyền thông dữ liệu

Giảng viên hướng dẫn: Th.S. Bùi Duy Cương

2.Nhận xét:

.....

.....

.....

.....

.....

.....

.....

.....

.....

TP. Hồ Chí minh, ngày tháng năm 2025

Giảng viên hướng dẫn

(Ký và ghi rõ họ và tên)

LỜI CẢM ƠN

Trước tiên, chúng em xin gửi lời cảm ơn chân thành và sâu sắc nhất đến Quý Thầy Cô Khoa Công Nghệ Thông Tin – Đại Học Văn Lang đã tận tình hướng dẫn, truyền đạt kiến thức và hỗ trợ chúng em trong suốt quá trình học tập và thực hiện đồ án này. Những chỉ dẫn quý báu từ Thầy Cô đã giúp chúng em hoàn thiện kiến thức chuyên môn và kỹ năng cần thiết để hoàn thành tốt nhiệm vụ được giao.

Đặc biệt, chúng em gửi lời tri ân sâu sắc đến Thầy Bùi Duy Cương, người đã luôn đồng hành, động viên và hỗ trợ chúng em trong suốt quá trình nghiên cứu và hoàn thiện đồ án. Những góp ý chân thành và sự tận tâm của Thầy đã giúp chúng em hoàn thiện tốt hơn đề tài này.

Chúng em xin chân thành cảm ơn!

TP. Hồ Chí minh, ngày tháng năm 2025

Sinh viên thực hiện

(Ký và ghi rõ họ và tên)

(NhómTrưởng)



Lâm Xuân Phú

MỤC LỤC

CHƯƠNG I: MỞ ĐẦU 7
1. Lý do chọn đề tài 7
2. Đối tượng, phạm vi nghiên cứu 7
2.1. Đối tượng nghiên cứu 7
2.2. Phạm vi nghiên cứu 7
3. Phương pháp nghiên cứu 7
3.1. Nghiên cứu lý thuyết 8
3.2. Nghiên cứu thực nghiệm 8
3.3. Phân tích và đánh giá 8
CHƯƠNG II: CƠ SỞ LÝ THUYẾT 9
1. Khái niệm về Kerberos 9
2. Lịch sử phát triển 9
3. Vị trí của Kerberos trong hệ thống mạng 10
4. Ưu điểm và nhược điểm của Kerberos 10
4.1. Ưu điểm 10
4.2. Nhược điểm 10
5. Kỹ thuật tấn công và biện pháp phòng chống Kerberos 11
5.1. Tấn công Kerberos 1: 11
5.2. Tấn công Kerberos 2: 12
5.3. Tấn công Kerberos 3: 13
6. Các công cụ triển khai thực nghiệm 14
6.1. Môi trường và phần mềm hỗ trợ Kerberos 14
6.2. Công cụ mô phỏng và kiểm tra 15
6.3. Công cụ phân tích và bảo mật 15
7. Kerberos Ticket Forging 15
7.1. Khái niệm về Kerberos Ticket Forging 15
7.2. Kịch bản tấn công bằng hình thức Kerberos Ticket Forging. 16
7.2.1. Kịch bản 1. 16
7.2.2. Kịch bản 2. 16

7.3. Môi trường và phần mềm hỗ trợ 16
7.4. Công cụ mô phỏng và kiểm tra 16
7.5. Công cụ phân tích và bảo mật 17
CHƯƠNG III: THỰC NGHIỆM 18
3.1. Môi trường thực hiện 18
3.2. Công cụ thực hiện. 18
3.3. Kết quả thực nghiệm. 20
3.3.1. Chuẩn bị. 20
3.3.2. Thực hiện tấn công 24
3.4. Các biện pháp phòng chống Kerberos Ticket Forging. 28
3.5. Tổng kết 28
TÀI LIỆU THAM KHẢO 29

DANH MỤC HÌNH ẢNH

Hình 1: Máy Windows Server 2022 (Máy mục tiêu) 18

Hình 2: Máy Windows 10 (Máy tấn công) 18

Hình 3: Giao diện của công cụ Mimikatz 19

Hình 4: Cấu hình hệ thống AD DS của server. 20

Hình 5: Tạo người dùng để máy khác có thể join Domain thông qua người dùng đó. 20

Hình 6: Hướng dẫn join vào Domain (1). 21

Hình 7: Nhập tên của Domain. 22

Hình 8: Nhập thông tin của User thuộc Domain. 22

Hình 9: Đã join vào Domain thành công. 23

Hình 10: Nhập thông tin đăng nhập của User thuộc Domain. 23

Hình 11: Thu thập thông tin của Admin. 24

Hình 12: Khởi động Mimikatz. 25

Hình 13: Lấy NTLM Hash của tài khoản Admin. 26

Hình 14: Tạo Golden Ticket từ các dữ liệu đã thu thập được. 26

Hình 15: Thực hiện tiêm Kerberos ticket vào bộ nhớ của phiên làm việc hiện tại trên máy tính Windows 27

Hình 16: Màn hình kết quả cho thấy đã truy cập thành công file dữ liệu của Domain bằng quyền Administrator. 27

CHƯƠNG I: MỞ ĐẦU

1. Lý do chọn đề tài

Trong môi trường mạng hiện đại, việc bảo vệ thông tin và quản lý quyền truy cập người dùng là một trong những ưu tiên hàng đầu của các tổ chức. Giao thức Kerberos được phát triển nhằm mục tiêu xác thực người dùng một cách an toàn trong môi trường mạng không tin cậy, điển hình là các hệ thống sử dụng Windows Active Directory. Tuy nhiên, dù Kerberos được thiết kế với nhiều lớp bảo mật, nó vẫn có thể bị khai thác nếu kẻ tấn công chiếm được các thông tin nhạy cảm trong hệ thống. Một trong những hình thức tấn công nguy hiểm là **Kerberos** , cho phép kẻ tấn công giả mạo vé truy cập (ticket) để chiếm quyền điều khiển hệ thống.

2. Đối tượng, phạm vi nghiên cứu

2.1. Đối tượng nghiên cứu

- Cách thức tấn công của giao thức Kerberos, đặc biệt là cơ chế xác thực tập trung, sử dụng vé, và mã hóa.

- Các thành phần chính như Centralised authentication, Tickets, Encryption, Mutual authentication, Operation in distributed environments, và cách chúng tương tác với client và Server.

- Các ưu điểm và nhược điểm của Kerberos, bao gồm các kỹ thuật tấn công phổ biến như Kerberos User Enumeration, AS-REP Roasting, Kerberoasting, và Kerberos Ticket Forging.

- Các công cụ và phương pháp triển khai thực nghiệm Kerberos, như MIT Kerberos, Wireshark, và các công cụ bảo mật như Splunk, Mimikatz.

2.2. Phạm vi nghiên cứu

- Tập trung vào lý thuyết, phân tích và thực nghiệm giao thức Kerberos

- Nghiên cứu dựa trên các tài liệu tham khảo, công cụ, đảm bảo tính cập nhật và phù hợp với công nghệ hiện đại.

3. Phương pháp nghiên cứu

Phương pháp nghiên cứu trong bài này tập trung vào việc phân tích và mô phỏng một cuộc tấn công bảo mật thực tế nhắm vào hệ thống xác thực Kerberos trong môi trường Windows, cụ thể là tấn công Golden Ticket. Các bước nghiên cứu bao gồm:

- Nghiên cứu cơ chế hoạt động của hệ thống Kerberos, đặc biệt là cách Windows Server 2022 và Windows 10 xử lý xác thực domain. Đồng thời, tìm hiểu về công cụ Mimikatz và các kỹ thuật tấn công liên quan như Pass-The-Hash và Golden Ticket Attack.
- Sử dụng hai máy ảo (Windows Server 2022 và Windows 10) để tái hiện một môi trường doanh nghiệp thực tế. Windows Server 2022 được cấu hình làm máy chủ domain với Active Directory Domain Services (AD DS), trong khi Windows 10 đóng vai trò máy khách tấn công.
- Áp dụng công cụ Mimikatz để khai thác thông tin xác thực và thực hiện tấn công Golden Ticket. Các kỹ thuật bao gồm dump mật khẩu từ bộ nhớ, lấy NTLM hash của tài khoản krbtgt, và tạo vé Kerberos giả mạo.
- Sau khi thực hiện tấn công, phân tích các lỗ hổng bảo mật đã bị khai thác và đề xuất các biện pháp phòng chống nhằm tăng cường an toàn cho hệ thống.

3.1. Nghiên cứu lý thuyết

- Tìm hiểu định nghĩa về hệ thống Kerberos lịch sử phát triển và mục đích sử dụng trong an ninh mạng

- Nghiên cứu về hệ thống Kerberos, bao gồm nguyên lý hoạt động, cơ chế tấn công.

- Tìm hiểu các phương pháp tấn công của Kerberos.

3.2. Nghiên cứu thực nghiệm

- Cài đặt và cấu hình hai máy ảo là Windows Server 2022 (máy mục tiêu) và Windows 10 (máy tấn công).

- Sử dụng Mimikatz trên Windows 10: lấy Domain SID, NTLM hash của krbtgt, tạo Golden Ticket, và truy cập tài nguyên Server mà không cần mật khẩu.

3.3. Phân tích và đánh giá

- Tấn công khai thác lỗ hổng Kerberos bằng cách tạo vé giả mạo, cho phép kiểm soát toàn domain.

- Mimikatz dễ dàng trích xuất thông tin xác thực, nhưng hệ thống thiếu cơ chế phát hiện và bảo vệ tài khoản nhạy cảm như krbtgt.

- Tấn công thành công, chứng minh rủi ro lớn từ Golden Ticket.

- Biện pháp phòng chống (giới hạn quyền krbtgt, dùng gMSA, Credential Guard, chính sách mạnh) hiệu quả nhưng cần giám sát, cập nhật, và đào tạo nhân sự để tăng cường an toàn.

CHƯƠNG II: CƠ SỞ LÝ THUYẾT

1. Khái niệm về Kerberos

Kerberos là một giao thức xác thực mạng, chủ yếu được sử dụng để cho phép người dùng và dịch vụ trên mạng xác minh danh tính của họ.

Nó dựa trên khái niệm 'trusted third party (bên thứ ba đáng tin cậy)', nghĩa là nó sử dụng máy chủ xác thực tập trung để xác thực danh tính và phân phối vé cấp quyền truy cập vào các dịch vụ.

Các yếu tố chính của Kerberos:

- **Centralised authentication (Xác thực tập trung):** Máy chủ xác thực, được gọi là Trung tâm phân phối khóa (KDC), chịu trách nhiệm xác thực người dùng và dịch vụ. Xác thực này gồm hai giai đoạn: giai đoạn xác thực và giai đoạn phiếu dịch vụ.
- **Tickets (vé):** Thay vì yêu cầu người dùng gửi mật khẩu cho từng dịch vụ, Kerberos sử dụng vé tạm thời để chứng minh rằng người dùng đã được xác thực. Những vé này được mã hóa và được KDC cấp.
- **Encryption (Mã hóa):** Kerberos sử dụng các kỹ thuật mã hóa để đảm bảo rằng thông tin liên lạc giữa máy khách và máy chủ được an toàn. Mỗi vé được mã hóa bằng khóa bí mật chỉ KDC và các dịch vụ liên quan biết.
- **Mutual authentication (Xác thực lẫn nhau):** Trong Kerberos, không chỉ máy khách chứng minh danh tính của mình với máy chủ mà máy chủ cũng chứng minh danh tính của mình với máy khách, đảm bảo rằng cả hai bên đều xác thực.
- **Operation in distributed environments (Hoạt động trong môi trường phân tán):** Kerberos thường được sử dụng trong môi trường có nhiều hệ thống tương tác, chẳng hạn như mạng công ty. Nó cũng được sử dụng trong một số hệ điều hành như Windows (thông qua Active Directory) và trong các hệ thống Unix/Linux.

2. Lịch sử phát triển

- Học viện kỹ thuật Massachusetts (MIT) phát triển Kerberos để bảo vệ các dịch vụ mạng cung cấp bởi dự án Athena
- Giao thức đã được phát triển dưới nhiều phiên bản, trong đó các phiên bản từ 1 đến 3 chỉ dùng trong nội bộ MIT.

- Các tác giả chính của phiên bản 4, Steve Miller và Clifford Neuman, đã xuất bản giao thức ra công chúng vào cuối thập niên 1980, mặc dù mục đích chính của họ là chi phục vụ cho dự án Athena.
- Phiên bản 5, do John Kohl và Clifford Neuman thiết kế, xuất hiện trong tài liệu (RFC1510) RFC 1510 - The Kerberos Network Authentication Service (V5) vào năm 1993 (được thay thế bởi RFC 4120 vào năm 2005 - RFC 4120 - The Kerberos Network Authentication Service (V5) với mục đích sửa lỗi của phiên bản 4.

3. Vị trí của Kerberos trong hệ thống mạng

Kerberos thường được triển khai trong các mạng doanh nghiệp lớn, nơi yêu cầu xác thực tập trung và an toàn là cần thiết. Nó hoạt động ở lớp ứng dụng và sử dụng TCP/UDP để truyền thông. Kerberos đóng vai trò là một phần quan trọng của cơ sở hạ tầng an ninh mạng, đảm bảo rằng chỉ những người dùng và dịch vụ được ủy quyền mới có thể truy cập tài nguyên mạng.

4. Ưu điểm và nhược điểm của Kerberos

4.1. Ưu điểm

• Hỗ trợ xác thực hai chiều: Cả **client và server đều phải xác thực lẫn nhau**, giúp tránh giả mạo dịch vụ.

• Quản lý phiên làm việc hiệu quả: Người dùng chỉ cần xác thực một lần (SSO - Single Sign-On) và có thể truy cập nhiều dịch vụ khác nhau mà không cần nhập lại mật khẩu.

• Quản lý tập trung: **KDC** quản lý toàn bộ quá trình xác thực, giúp kiểm soát người dùng và tài nguyên dễ dàng.

• Hỗ trợ trên nhiều nền tảng: Được sử dụng rộng rãi trong **Windows (Active Directory), Linux/Unix, macOS**, và các hệ thống lớn như MIT Kerberos, OpenLDAP.

4.2. Nhược điểm

• Phụ thuộc vào KDC: Nếu **KDC bị lỗi hoặc bị tấn công**, toàn bộ hệ thống xác thực sẽ không hoạt động.

• Yêu cầu đồng bộ thời gian chính xác: Kerberos yêu cầu máy **client, server, và KDC phải đồng bộ thời gian (thường sai lệch không quá 5 phút)**. Nếu thời gian bị lệch, quá trình xác thực sẽ thất bại.

• Khó triển khai và quản lý: Cấu hình Kerberos phức tạp, cần phải thiết lập **KDC, các chính sách vé (ticket policies), mã hóa**,.... Yêu cầu **quản lý cẩn thận mật khẩu của tài khoản dịch vụ (Service Accounts)** để tránh bị tấn công.

• Không chống được các cuộc tấn công từ nội bộ: Nếu một **quản trị viên hoặc người dùng có quyền cao bị hack**, hacker có thể lấy vé Kerberos hợp lệ để truy cập hệ thống.

5. Kỹ thuật tấn công và biện pháp phòng chống Kerberos

5.1. Tấn công Kerberos 1:

Kerberos User Enumeration (Liệt kê người dùng Kerberos)

Vì Kerberos là một giao thức xác thực, nên có thể xảy ra các cuộc tấn công Brute force vào giao thức này. Một cuộc tấn công Brute force vào Kerberos có một lợi thế rõ ràng so với các cuộc tấn công vào các phương pháp xác thực khác: không cần tài khoản miền để thực hiện cuộc tấn công, chỉ cần kết nối đến KDC.

Tấn công

- Khi gửi yêu cầu xác thực (AS-REQ), kẻ tấn công có thể sử dụng phản hồi từ KDC để xác định xem người dùng có tồn tại hay không. Điều này cho phép kẻ tấn công thực hiện tấn công bằng cách sử dụng danh sách từ. Ở đây, kẻ tấn công có lợi khi các lỗi xác thực trước Kerberos trong Active Directory không được ghi lại với sự kiện lỗi đăng nhập thông thường (4625), mà với **ID sự kiện cụ thể là 4771 (xác thực trước Kerberos không thành công)** . Hoàn cảnh này làm giảm khả năng phát hiện ra cuộc tấn công.
- Cũng có thể sử dụng Kerberos User Enumeration để xác định tài khoản người dùng mà không cần xác thực trước.

Biện pháp

- Liệt kê người dùng Kerberos có thể khó khắc phục sự cố vì nó phụ thuộc vào việc giám sát Kerberos tốt. Việc giám sát này phải có khả năng phát hiện số lượng yêu cầu AS-REQ không thực tế mà không có yêu cầu theo dõi.

- Để ghi lại các sự kiện này trong nhật ký sự kiện, trước tiên bạn phải điều **chỉnh Cài đặt mặc định để theo dõi các lần đăng nhập tài khoản.** Mỗi giá trị **" thành công và thất bại ",** do đó các lần đăng nhập không thành công cũng được ghi lại. Sau đó, có thể xem nhật ký sự kiện sau khi tìm kiếm **EventID 4768 và chuỗi "0x6"** có trong đó.

5.2. Tấn công Kerberos 2:

AS-REP Roasting

AS-REP Roasting là một cuộc tấn công Kerberos trong đó kẻ tấn công mã hóa các phần của **tin nhắn AS_REP** đánh cắp từ tài khoản người dùng để sau đó bẻ khóa chúng ngoại tuyến. Điều kiện tiên quyết cho việc này là tài khoản đang đề cập có xác thực trước Kerberos bị vô hiệu hóa. Nếu vậy, bất kỳ ai cũng có thể gửi yêu cầu AS_REQ đến KDC thay mặt cho người dùng đó và nhận được tin nhắn AS_REP. AS_REP này chứa thông tin được mã hóa bằng hàm băm NTLM của người dùng. Phần được mã hóa này của AS_REP sau đó có thể được sử dụng để **bẻ khóa mật khẩu** bị khai thác.

Tấn công

- **Khi xác thực trước được bật** , người dùng cần truy cập vào tài nguyên sẽ bắt đầu quy trình xác thực Kerberos bằng cách gửi tin nhắn yêu cầu máy chủ xác thực (AS-REQ) đến bộ điều khiển miền (DC). Dấu thời gian trong tin nhắn này được mã hóa bằng hàm băm của mật khẩu người dùng. Nếu DC có thể khớp dấu thời gian này với bản ghi riêng của nó về hàm băm mật khẩu người dùng, thì nó sẽ gửi lại tin nhắn Phản hồi máy chủ xác thực (AS-REP). Tin nhắn AS-REP này chứa TGT sẽ được người dùng này sử dụng cho các yêu cầu truy cập trong tương lai. Tin nhắn AS-REP cũng chứa thông tin được băm bằng mật khẩu của người dùng. **Tuy nhiên, nếu xác thực trước bị tắt** , kẻ tấn công có thể yêu cầu thông tin xác thực cho bất kỳ người dùng nào và nhận được tin nhắn AS-REP từ DC để phản hồi. Tin nhắn này chứa thông tin đã băm được mã hóa bằng mật khẩu của người dùng. Sau đó, kẻ tấn công có thể cố gắng bẻ khóa mật khẩu của người dùng ngoại tuyến bằng cách cố gắng bẻ khóa krb5asrep bằng các đầu vào thích hợp. Nếu có thể

giải mã AS_REP thành văn bản thuần túy có nghĩa thì khóa được sử dụng sẽ tương ứng với mật khẩu của người dùng.

- Có lợi cho kẻ tấn công: Không cần tài khoản miền cho cuộc tấn công Kerberos này, chỉ cần kết nối đến KDC. Tuy nhiên, nếu kẻ tấn công có người dùng miền, chúng có thể sử dụng truy vấn LDAP để tìm người dùng trong miền mà không cần xác thực trước Kerberos. Nếu không, tên người dùng phải được đoán. Tuy nhiên, sự kết hợp với các cuộc tấn công Kerberos như liệt kê người dùng Kerberos làm cho việc này dễ dàng hơn nhiều.

Biện pháp

- Trước tiên, hãy đảm bảo tất cả tài khoản trong miền đã **bật xác thực trước Kerberos** . (Đây là thiết lập mặc định kể từ Kerberos v5.) Để kiểm tra xem người dùng nào trong miền đã thiết lập thiết lập này không đúng, bạn có thể thực hiện truy vấn LDAP tương ứng.
- Ngoài ra, việc thực thi có hiệu quả hơn **Chính sách mật khẩu** cần thiết cho Active Directory để đảm bảo môi trường của bạn không dễ bị tấn công AS-REP. Nếu sử dụng mật khẩu mạnh trên tài khoản dễ bị tấn công, thì hầu như không thể "phá vỡ" mã hóa bằng cách đoán mật khẩu. Một chính sách mật khẩu an toàn, có thể thực thi và do đó hiệu quả cũng giúp đảm bảo người dùng sử dụng mật khẩu mạnh ở nơi khác. Sau đó, chúng cũng không dễ đoán hoặc dễ bị tấn công bằng cách dùng vũ lực hoặc các cuộc tấn công mật khẩu phổ biến khác.

5.3. Tấn công Kerberos 3:

Kerberos rusting

Mục tiêu của Kerberoasting là **TGS ticket** cho các dịch vụ chạy thay mặt cho tài khoản người dùng trong AD chứ không phải tài khoản máy tính. Tại sao điều này hữu ích? Một số ticket TGS này được mã hóa bằng khóa có nguồn gốc từ mật khẩu người dùng. Do đó, kẻ tấn công có thể sử dụng các cuộc tấn công brute force để giải mã thông tin đăng nhập đang được đề cập ngoại tuyến.

Chỉ cần một tài khoản miền để thực hiện Kerberoasting, **Tên nguyên tắc dịch vụ (SPN)** có thể yêu cầu – bất kỳ ai cũng có thể thực hiện vì không yêu cầu quyền đặc biệt nào.

Tấn công

- Trong một cuộc tấn công Kerberoasting, kẻ tấn công yêu cầu các vé TGS (một hoặc tất cả) có chứa mật khẩu được mã hóa của người dùng. Yêu cầu TGS có thể được thực hiện bằng cách chỉ định bất kỳ SPN nào.
- SPN được xác thực Kerberos sử dụng để liên kết một phiên bản dịch vụ với một tài khoản người dùng. Điều này cho phép ứng dụng khách hàng yêu cầu dịch vụ xác thực một tài khoản ngay cả khi khách hàng không biết tên tài khoản.
- Khi **yêu cầu TGS** chỉ định một **SPN** được cung cấp và SPN này được đăng ký trong Active Directory, bộ điều khiển miền sẽ cung cấp một vé. Vé này có **khóa bí mật** của tài khoản đang chạy dịch vụ. Với thông tin này, kẻ tấn công hiện có thể cố gắng sử dụng vé ngoại tuyến **để tấn công bằng vũ lực** để bẻ khóa và do đó lấy được mật khẩu dạng văn bản thuần túy của người dùng.

Biện pháp

- Để bảo vệ chống lại loại tấn công Kerberos này, SPN trên tài khoản người dùng phải có lợi cho tài khoản máy tính . Nếu cần, chức năng **" Group Managed Service Accounts (gMSA) "** của Microsoft. Điều này đảm bảo rằng mật khẩu tài khoản mạnh mẽ và được thay đổi thường xuyên và tự động.
- Có một số điều kiện tiên quyết để sử dụng gMSA:
    - Cấp độ chức năng miền 2012 trở lên
    - Hệ điều hành Windows Server 2012 R2 trở lên
    - Cài đặt mô-đun PowerShell của Active Directory trên DC và các máy chủ tương ứng mà gMSA sẽ được sử dụng
    - SQL Server 2014 trở lên (nếu sử dụng gMSA cho SQL Server)

6. Các công cụ triển khai thực nghiệm

6.1. Môi trường và phần mềm hỗ trợ Kerberos

Hệ điều hành tích hợp sẵn Kerberos:

- Các hệ điều hành như Microsoft Windows, Linux, FreeBSD, và Mac OS X đã tích hợp sẵn hỗ trợ Kerberos.

- Trong Windows, Kerberos là phương pháp xác thực mặc định trong Active Directory.
- Trên Linux và FreeBSD, các phiên bản như MIT Kerberos hoặc Heimdal được sử dụng.

MIT Kerberos:

- Là phiên bản gốc, miễn phí và mã nguồn mở, cung cấp các công cụ như **kinit, klist, kdestroy**, và **kadmin.**
- **kinit:** Dùng để lấy vé từ Key Distribution Center (KDC).
- **klist:** Hiển thị danh sách vé hiện có.
- **kadmin:** Quản lý cơ sở dữ liệu Kerberos (tạo, xóa principal).

6.2. Công cụ mô phỏng và kiểm tra

Wireshark:

- Dùng để bắt và phân tích gói tin Kerberos (AS_REQ, AS_REP, TGS_REQ, TGS_REP).
- Giúp kiểm tra tính đúng đắn của giao thức trong thực tế.

Mã nguồn mở và dự án thử nghiệm:

- Các dự án mã nguồn mở sử dụng Python, C, hoặc Java để mô phỏng các giai đoạn của Kerberos (xác thực với AS, lấy TGT, lấy Service Ticket).

6.3. Công cụ phân tích và bảo mật

Splunk/SIEM:

- Giám sát và phân tích nhật ký liên quan đến Kerberos, phát hiện các vấn đề hoặc tấn công (như Pass-the-Hash, Replay Attack).

Burp Suite và Metasploit:

- Dùng để kiểm tra lỗ hổng bảo mật của Kerberos, đặc biệt trong các môi trường thử nghiệm.

7. Kerberos Ticket Forging

7.1. Khái niệm về Kerberos Ticket Forging

Kerberos Ticket Forging (giả mạo vé Kerberos) là kỹ thuật tấn công trong đó kẻ tấn công tạo ra hoặc sửa đổi vé (ticket) Kerberos bất hợp pháp để truy cập trái phép vào các dịch vụ hoặc tài nguyên trong mạng sử dụng giao thức Kerberos (thường thấy trong môi trường Windows Active Directory).

Kerberos hoạt động dựa trên vé (ticket) xác thực do **Key Distribution Center (KDC)** cấp. Nếu kẻ tấn công có thể giả mạo hoặc tạo ra vé hợp lệ, họ có thể **mạo danh người dùng** hoặc **chiếm quyền kiểm soát hệ thống**.

Các hình thức tấn công Kerberos Ticket Forging phổ biến:

- Golden Ticket Attack: Kẻ tấn công giả mạo **TGT (Ticket Granting Ticket)** bằng cách chiếm được **NTLM hash của tài khoản KRBTGT** (tài khoản cấp vé trong Active Directory).
- Silver Ticket Attack: Kẻ tấn công giả mạo **TGS (Ticket Granting Service)** để truy cập vào một dịch vụ cụ thể mà không cần thông qua KDC.
- Pass-the-Ticket (PTT) Attack: Kẻ tấn công **trích xuất và sử dụng lại** vé Kerberos hợp lệ từ bộ nhớ máy tính để truy cập tài nguyên mà không cần mật khẩu.
- AS-REP Roasting Attack: Tấn công vào các tài khoản **không yêu cầu pre-authentication** để trích xuất và bẻ khóa **AS-REP** (Authentication Server Response).

7.2. Kịch bản tấn công bằng hình thức Kerberos Ticket Forging.

7.2.1. Kịch bản 1.

Bạn là Pentester đang thực hiện đánh giá mức độ bảo mật của một hệ thống server có sử dụng hình thức bảo mật Kerberos. Bạn sẽ thực hiện tấn công vào server này thông qua phương thức **Golden Ticket Attack** để từ đó đánh giá được mức độ bảo mật cũng như là thực hiện các biện pháp phòng chống để tăng cường tính bảo mật cho server.

7.2.2. Kịch bản 2.

Bạn là một hacker đang sử dụng hình thức tấn công **Golden Ticket Attack** để có thể truy cập vào mọi tài nguyên trong domain thông qua tài khoản KRGBTG.

7.3. Môi trường và phần mềm hỗ trợ

- Hệ điều hành tích hợp Kerberos: Windows (Active Directory), Linux, FreeBSD, Mac OS X.
- MIT Kerberos: Cung cấp công cụ như kinit, klist, kdestroy, kadmin để quản lý và kiểm tra.

7.4. Công cụ mô phỏng và kiểm tra

- Wireshark: Phân tích gói tin Kerberos (AS_REQ, AS_REP, TGS_REQ, TGS_REP).

- Mã nguồn mở: Python, C, Java để mô phỏng các giai đoạn xác thực.

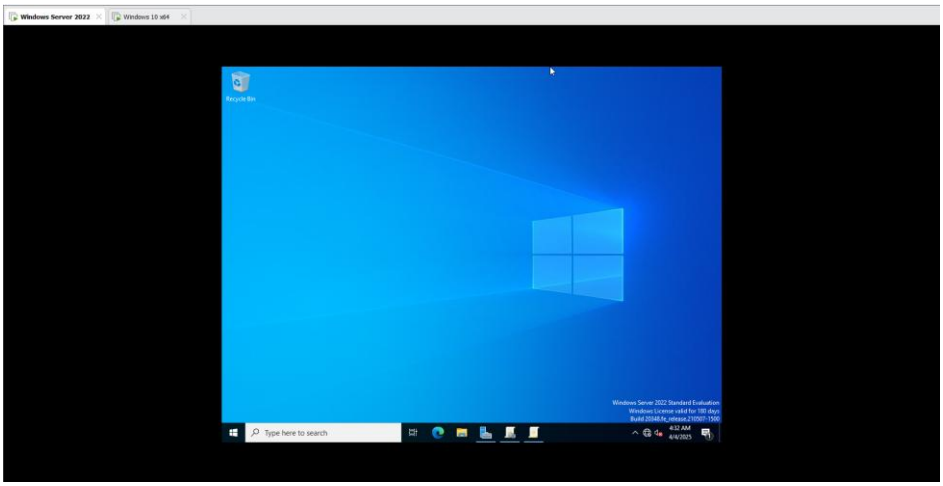
7.5. Công cụ phân tích và bảo mật

- Splunk/SIEM: Giám sát nhật ký, phát hiện tấn công.
- Burp Suite, Metasploit: Kiểm tra lỗ hổng bảo mật.

CHƯƠNG III: THỰC NGHIỆM

3.1. Môi trường thực hiện.

Windows Server 2022: Sẽ là máy được cài sẵn hình thức bảo mật Kerberos, đồng thời cung cấp một tài khoản người dùng để cho máy còn lại có thể truy cập vào Domain của server.



Hình 1: Máy Windows Server 2022 (Máy mục tiêu)

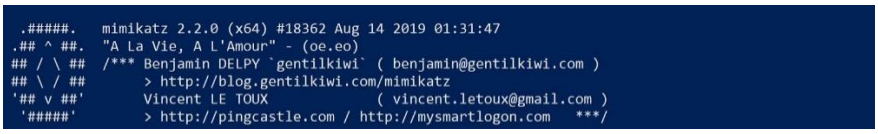
Windows 10: Máy còn lại sẽ join vào domain thông qua tài khoản người dùng được cấp và sẽ dùng công cụ tấn công để khai thác lỗ hổng bảo mật có liên quan đến hệ thống Kerberos.



Hình 2: Máy Windows 10 (Máy tấn công)

3.2. Công cụ thực hiện.

Trong bài này, ta sẽ sử dụng công cụ **Mimikatz** để tấn công Golden Ticket từ máy Windows 10 đến máy Windows Server 2022.



Hình 3: Giao diện của công cụ Mimikatz

Mimikatz là một công cụ bảo mật mã nguồn mở được tạo ra để trích xuất mật khẩu, hash, mã PIN từ bộ nhớ Windows. Bên cạnh đó, nó còn có thể thực hiện các cuộc tấn công Kerberos. Ban đầu, Mimikatz được phát triển để nghiên cứu bảo mật, nhưng về sau đã trở thành công cụ phổ biến cho Pentesting và cả tấn công thực tế.

Cách hoạt động: Mimikatz hoạt động bằng cách khai thác cơ chế lưu trữ thông tin xác thực của Windows. Một số phương pháp chính mà Mimikatz sử dụng đó là:

- **Dump mật khẩu trong bộ nhớ:** Windows lưu trữ thông tin xác thực của người dùng trong bộ nhớ, Mimikatz có thể đọc chúng nếu có quyền SYSTEM. Nếu thành công, ta sẽ thấy username, domain, NTLM hash, thậm chí cả mật khẩu plaintext (trên một số phiên bản Windows cũ).
- **Pass-The-Hash:** Dùng NTLM hash để xác thực mà không cần biết mật khẩu thật.
- **Golden Ticket Attack:** Tạo vé Kerberos giả mạo bằng cách sử dụng hash của tài khoản krbtgt. Điều này giúp truy cập **bất kỳ tài nguyên nào trong domain** mà không cần mật khẩu thực.

Mục tiêu

Có toàn quyền truy cập và chỉnh sửa các file của máy Windows Server 2022.

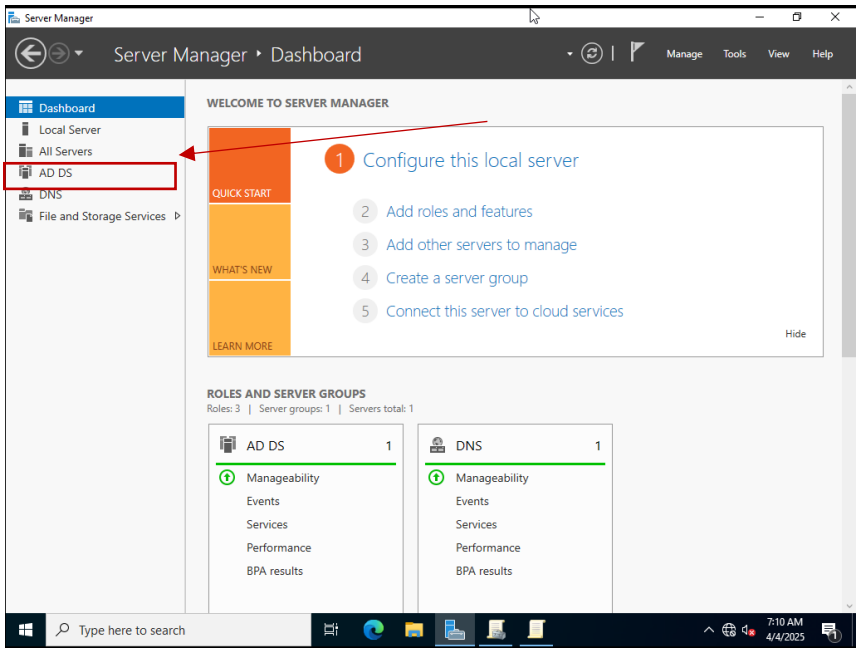
Đề xuất các biện pháp bảo mật để giảm thiểu rủi ro và tăng cường an toàn cho server.

3.3. Kết quả thực nghiệm.

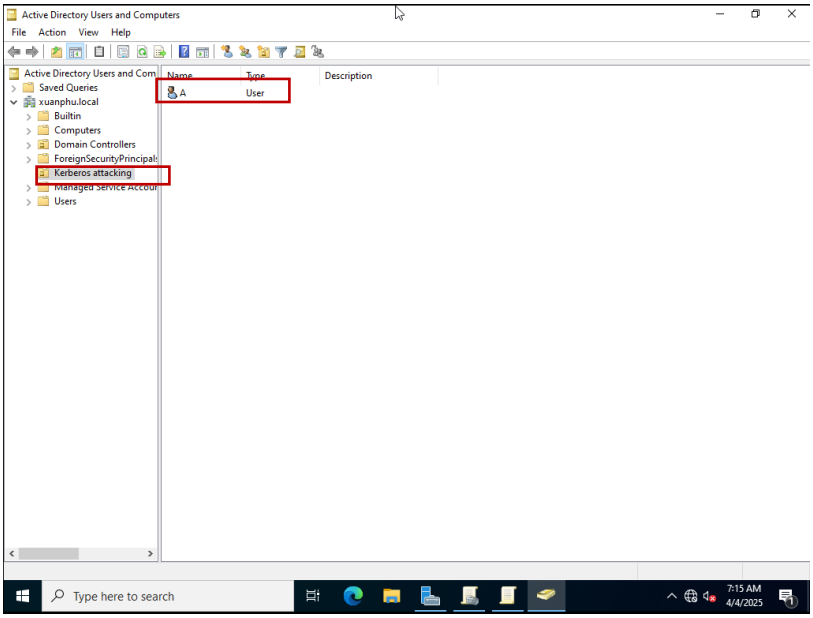
Ở trong bài này, ta sẽ thực hiện theo như kịch bản 1.

3.3.1. Chuẩn bị.

Cài đặt và set up 2 máy ảo Windows Server 2022 và Windows 10. Trên máy Windows Server 2022, cài đặt và cấu hình hệ thống Active Directory Domain & Service.



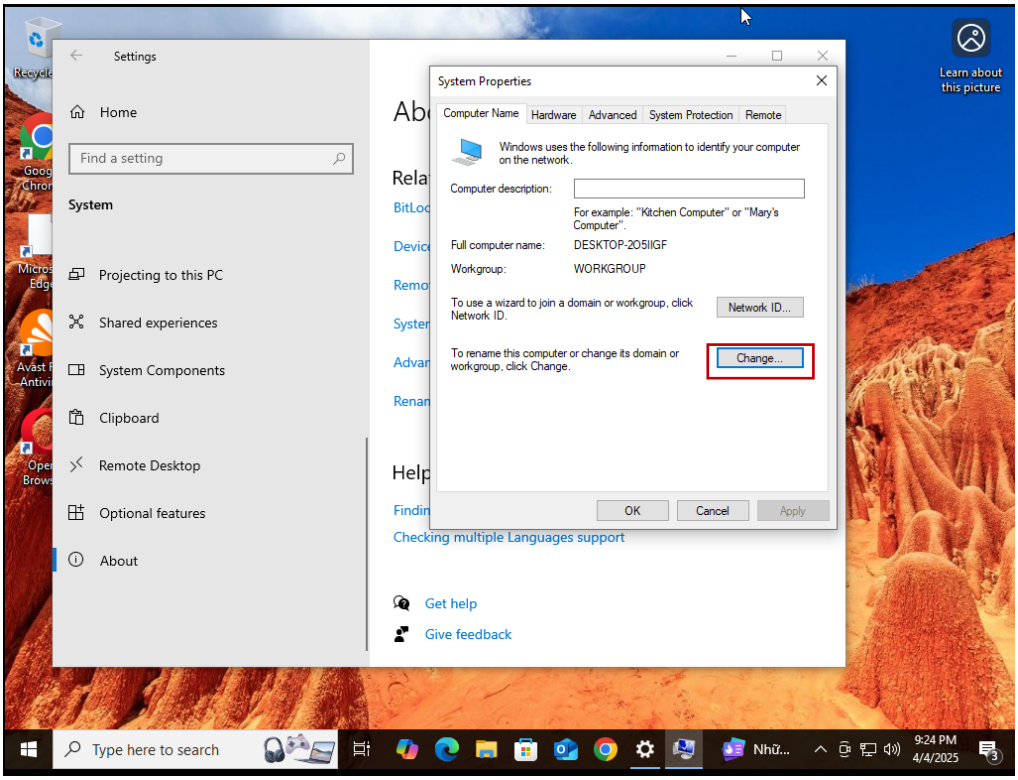
Hình 4: Cấu hình hệ thống AD DS của server.



Hình 5: Tạo người dùng để máy khác có thể join Domain thông qua người dùng đó.

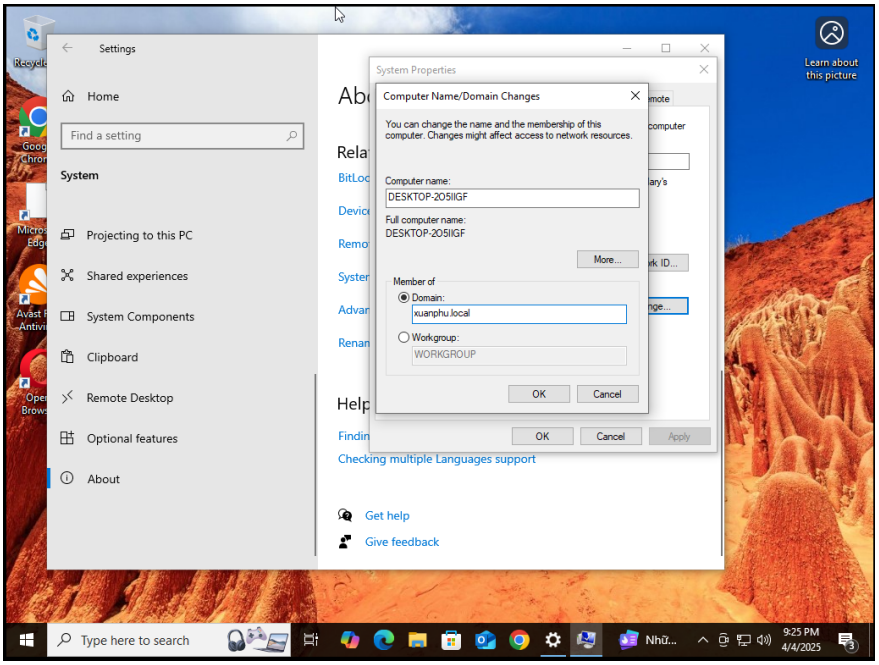
Trên Domain có tên **xuanphu.local** (trong trường hợp này) Tạo một Organization Unit (OU) mới (nếu cần thiết). Tiếp theo tạo một User mới có tên A, user này sẽ được máy windows 10 sử dụng để join vào domain.

Trên máy Windows 10, click theo trình tự sau: WINDOWS → Settings →System → About → Advanced system settings → chọn Tab Computer Name → Change...



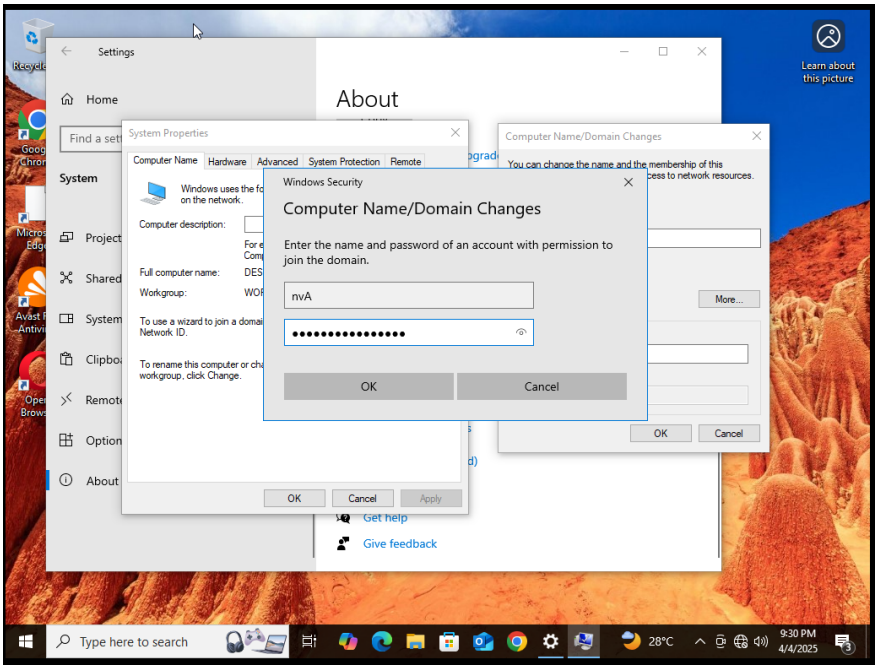
Hình 6: Hướng dẫn join vào Domain (1).

Trong mục Change... , click chọn Domain và gõ tên của domain, trong trường hợp này là **xuanphu.local** rồi bấm **OK** .



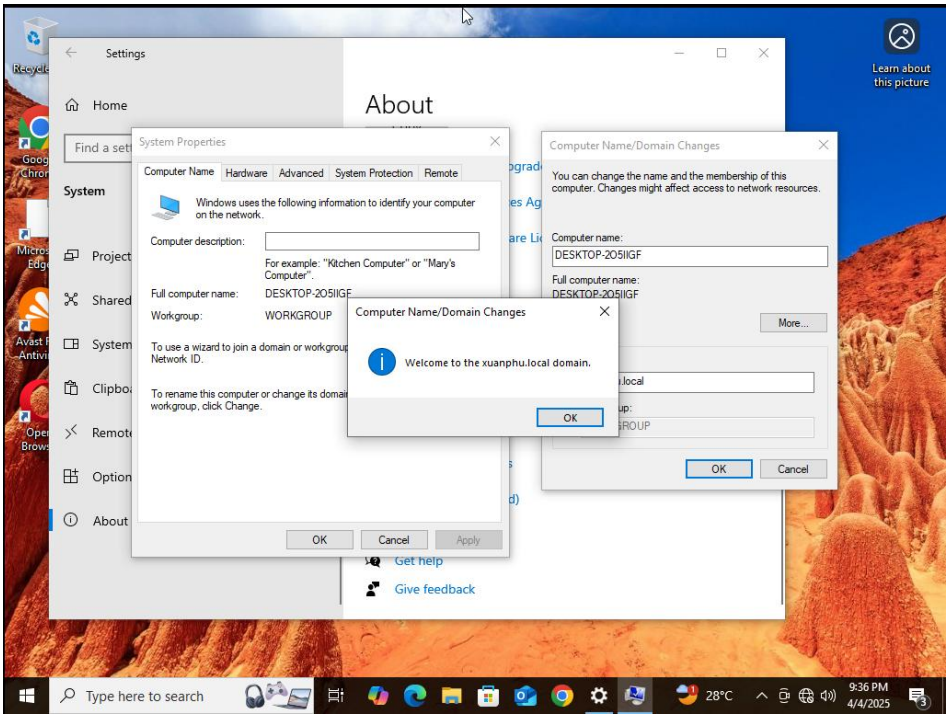
Hình 7: Nhập tên của Domain.

Tiếp theo đó, một cửa sổ thông báo sẽ hiện ra yêu cầu ta nhập tên đăng nhập và mật khẩu của User đã tạo bên AD DS của Windows Server 2022.



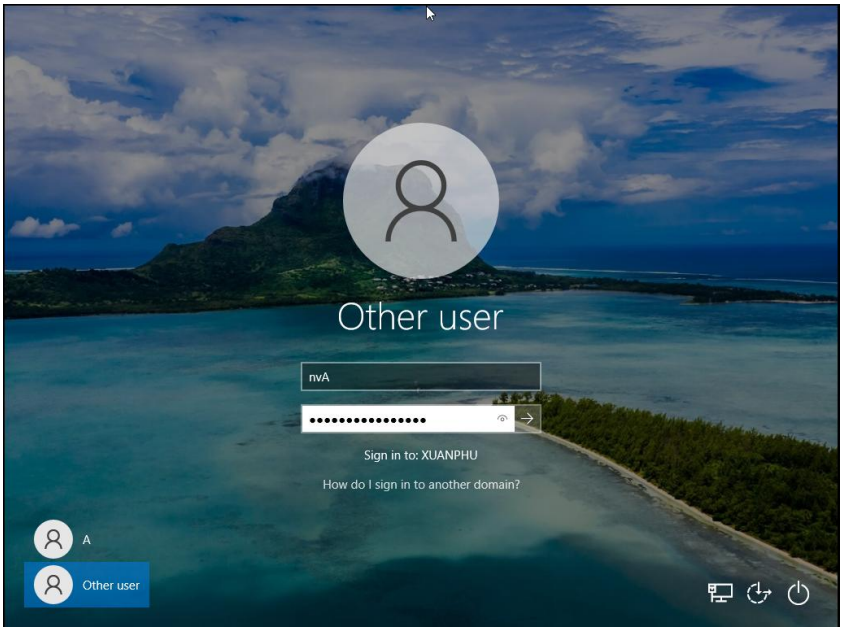
Hình 8: Nhập thông tin của User thuộc Domain.

Nếu thành công, thì một thông báo hiện lên với nội dung là ta đã thành công join vào domain.



Hình 9: Đã join vào Domain thành công.

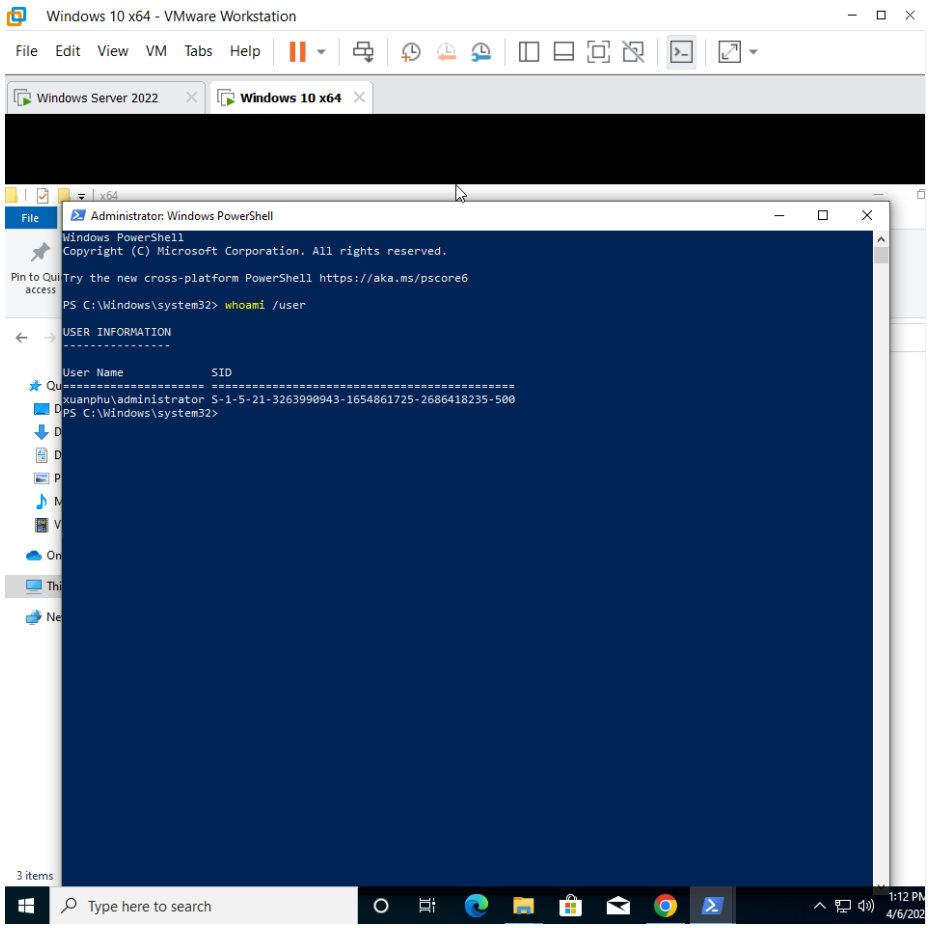
Sau khi nhận được thông báo join vào Domain thành công, khởi động lại Windows 10, chọn **Other Users** và nhập thông tin của User trong Domain để chính thức truy cập vào Domain.



Hình 10: Nhập thông tin đăng nhập của User thuộc Domain

3.3.2. Thực hiện tấn công

Trên máy Windows 10, thực hiện truy cập vào Windows Powershell với quyền Administrator. Gõ lệnh **whoami /user** để thu thập thông tin.



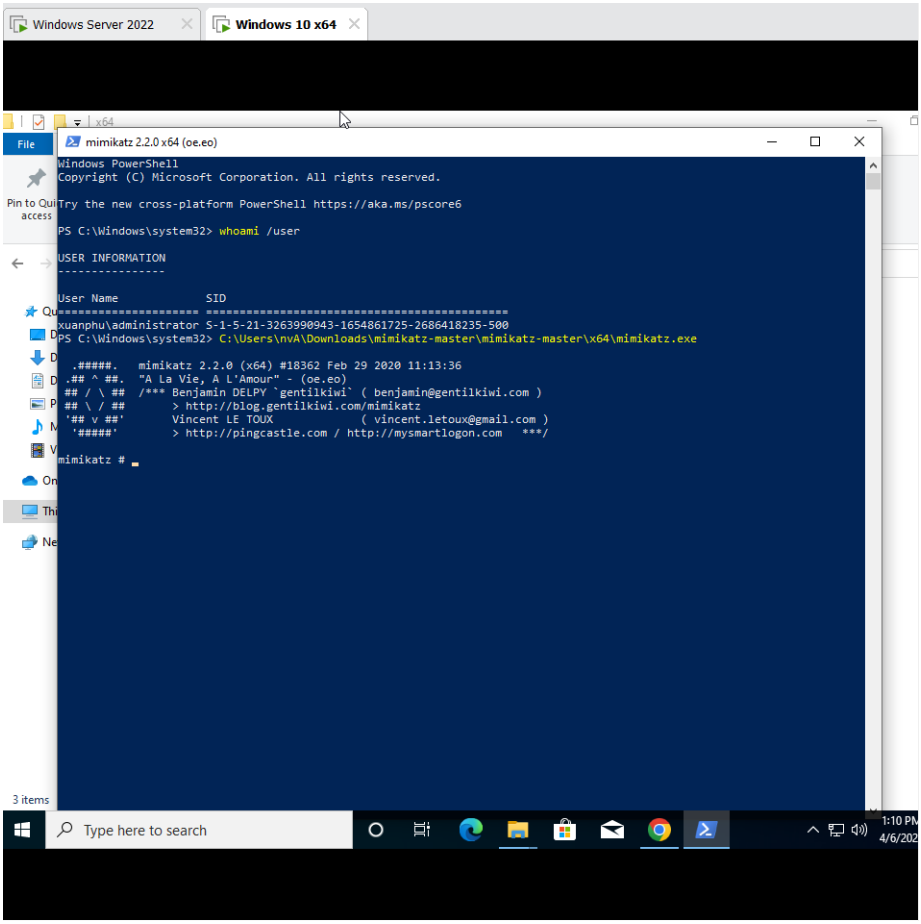
Hình 11: Thu thập thông tin của Admin.

Ở đây có 2 thông tin quan trọng mà ta cần chú ý:

- Đầu tiên là **Domain Name,** như đã tạo ở trên, Domain name trong trường hợp này sẽ là: **xuanphu.local**
- Thứ hai là **Domain SID,** trong trường hợp này sẽ là **S-1-5-21.....-500.**

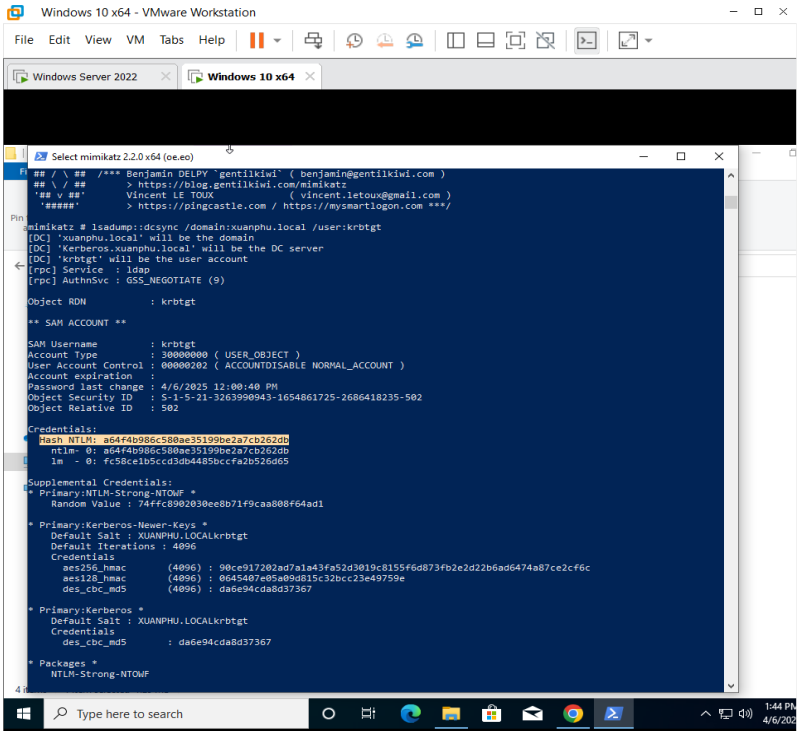
Giải thích: Bản chất của Golden Ticket Attack là tạo vé TGT Kerberos giả mạo, được ký bằng **key của krbtgt account** trong domain. Khi tạo Golden Ticket, kẻ tấn công đang giả dạng domain controller cấp vé hợp lệ cho bất kỳ người dùng nào. Nhưng kiểu tấn công này vẫn cần một số thông tin cụ thể như Domain SID để thực hiện, vì nếu không có SID, vé được tạo ra sẽ không hợp lệ hoặc không thể gán quyền chính xác, vì hệ thống sẽ không biết vé này đến từ domain nào hoặc User này thuộc nhóm nào.

Sau khi đã biết tên Domain và SID của admin thuộc Domain, ta thực hiện khởi động **mimikatz.exe** trên PowerShell.



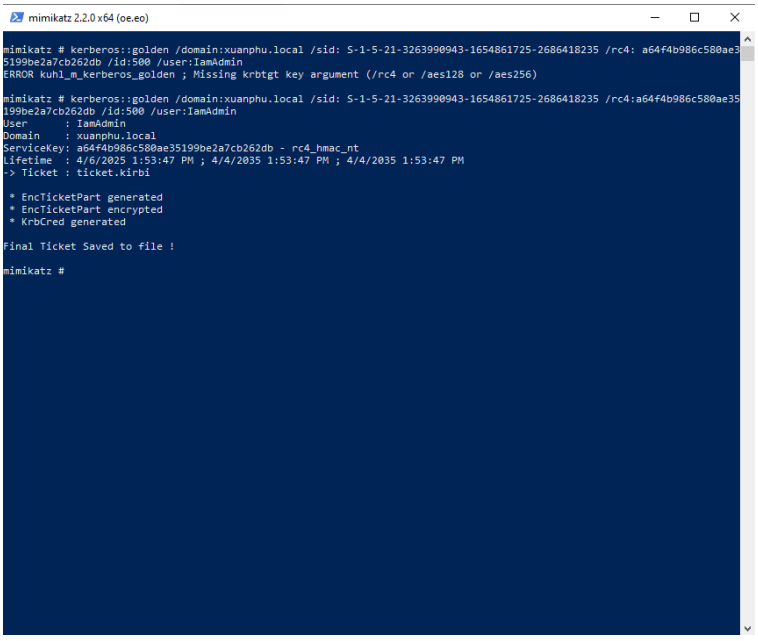
Hình 12: Khởi động Mimikatz.

Khi mimikatz được khởi động, chạy lệnh **lsadump::dcsync /domain: <domain name> /user:krbtgt** để tiến hành khai thác. Sau khi nhập lệnh xong, ta phải đi tìm **Hash NTLM** ở mục **Credentials.**



Hình 13: Lấy NTLM Hash của tài khoản Admin.

Tiếp theo, ta sẽ tạo một Golden Ticket từ những dữ liệu mà ta đã lấy được. Sử dụng lệnh **kerberos::golden /domain:<domain_Name> /sid:<domain_sid> /rc4:<krbtgt_hash> /id:500 /user:<đặt tên tùy ý>**

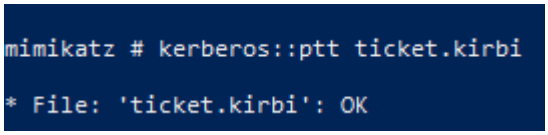


Hình 14: Tạo Golden Ticket từ các dữ liệu đã thu thập được.

Giải thích các tham số trong câu lệnh:

- **/domain:xuanphu.local:** Tên domain ta đang khai thác.
- **/sid:S-1-5-21-....235:** Domain SID, cần thiết để tạo SID hợp lệ cho user & group.
- **/rc4:a64f4....262db:** NTLM hash của tài khoản krbtgt – dùng để ký vé TGT giả
- **/id:500:** RID của user mà ta muốn giả danh – 500 là RID của Administrator
- **/user:IamAdmin:** Tên user giả danh

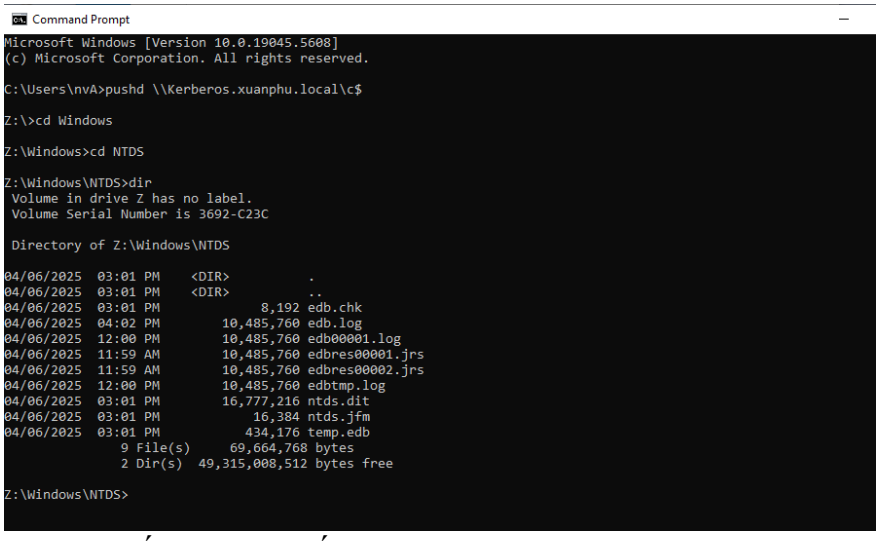
Tiếp theo, dùng lệnh **kerberos:ptt ticket.kirbi**



Hình 15: Thực hiện tiêm Kerberos ticket vào bộ nhớ của phiên làm việc hiện tại trên máy tính Windows

Giải thích: Câu lệnh này sẽ dùng để nạp 1 vé TGT có đuôi **.kirbi** đã tạo trước đó bằng lệnh **kerberos::golden** vào bộ nhớ LSASS.

Tiếp theo, truy cập vào **Command Promt** và gõ lệnh **pushd** \\Kerberos.xuanphu.local\c$ để truy cập vào ổ đĩa C của máy Windows Server 2022 mà không cần xác nhận quyền truy cập.



Hình 16: Màn hình kết quả cho thấy đã truy cập thành công file dữ liệu của Domain bằng quyền Administrator.

Sau đó, bạn sẽ có toàn quyền truy cập vào máy tính của Windows Server 2022.

3.4. Các biện pháp phòng chống Kerberos Ticket Forging.

1. **Giới hạn quyền truy cập vào tài khoản krbtgt:** Đặt mật khẩu phức tạp và thay đổi mật khẩu định kỳ, Giới hạn quyền truy cập thông qua các tài khoản krbtgt đối với những người dùng thông thường.
2. **Sử dụng Group Managed Service Accounts** thay vì tài khoản dịch vụ thông thường giúp giảm nguy cơ bị tấn công.
3. **Áp dụng các chính sách bảo mật mạnh hơn cho các dịch vụ Kerberos** như AES hoặc cập nhật các chính sách Kerberos để yêu cầu mật khẩu dài và phức tạp hơn.
4. **Sử dụng Windows Defender Credential Guard** để bảo vệ thông tin chứng thực, bao gồm kerberos Tickets và NTLM hashes để tránh việc chúng bị khai thác qua công cụ mimikatz.
5. **Sử dụng Protected Users Group:** Các tài khoản trong nhóm Protected Users của Active Directory sẽ không cho phép xác thực bằng NTLM hoặc các phương thức xác thực yếu khác. Chỉ Kerberos với mã hóa mạnh sẽ được sử dụng

3.5. Tổng kết

Kerberos Ticket Forging cực kì nguy hiểm trong môi trường doanh nghiệp, cụ thể là hình thức tấn công Golden Ticket, khi mà kẻ tấn công lại có thể sử dụng một công cụ vốn được tạo ra nhằm để đánh giá hệ thống bảo mật nay lại có thể thực hiện một phương thức tấn công có thể gây hại đến một tổ chức lớn. Vì thế, nếu muốn sử dụng phương thức xác thực Kerberos cho Server, ta cần phải thực hiện các biện pháp bảo mật nghiêm ngặt có liên quan đến **tài khoản krbtgt** cũng như các công cụ mã hóa mạnh cho Kerberos, đồng thời giám sát hành vi của người dùng. Bên cạnh đó,người dùng trong hệ thống cần phải có trách nhiệm đặt ra những tiêu chuẩn phòng ngừa như thay đổi mật khẩu tài khoản quan trọng định kỳ hoặc kiểm soát quyền truy cập vào Domain, tránh để cho những hình thức tấn công có thể xảy ra từ bên ngoài hoặc bên trong hệ thống.

TÀI LIỆU THAM KHẢO

- "Kerberos:TheDefinitiveGuide"–JasonGarman: https://www.oreilly.com/library/view/kerberos-the-definitive/0596004036/
- https://vi.wikipedia.org/wiki/Giao_th%E1%BB%A9c_Kerberos
- https://www.vaadata.com/blog/what-is-kerberos-kerberos-authentication-explained/
- https://www.prosec-networks.com/en/blog/kerberos-attacks/
- https://web.mit.edu/kerberos/krb5-latest/doc/
- https://lethanhnamwork.com/trien-khai-giao-thuc-kerberos-huong-dan-chi-tiet/
- https://sec.vnpt.vn/2023/01/ky-thuat-attacking-kerberos-as-rep-roasting/
- https://github.com/hoangdh/kerberos-guide